Threat Analysis Report

รายงานวิเคราะห์มัลแวร์ USB Worm Snakedisk และ Yokai backdoor

04/10/2025

TLP:CLEAR

สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ
๑๒๐ ชั้น ๗ อาคารซี ศูนย์ราชการเฉลิมพระเกียรติ ๘๐ พรรษา ๕ ธันวาคม ๒๕๕๐
ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพมหานคร ๑๐๒๑๐ อีเมล saraban@ncsa.or.th

สารบัญ

สารบัญ 2
บทสรุปสำหรับผู้บริหาร 3
Threat Actor Profile 4
การวิเคราะห์เชิงเทคนิค 5
Technique Tactics and Procedures (MITRE ATT&CK) 6
Indicator of Compromise (IOCs) 7
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ 9
อ้างอิง (References) 10

บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้วิเคราะห์การแพร่กระจายของเครื่องมือโจมตีจากการพบการพัฒนาของเครื่องและกิจกรรมของกลุ่มผู้ไม่หวังดีที่เชื่อมโยงกับประเทศจีนในชื่อ Mustang Panda (หรือ Hive0154) โดยได้มีการพัฒนา USB Worm ใหม่ที่มีชื่อว่า **SnakeDisk** ซึ่งมีเป้าหมายการโจมตีเป็นเครื่องที่มีหมายเลข IP Address เป็นของประเทศไทยเท่านั้น พร้อมทั้งยังทำการติดตั้ง Backdoor **Yokai** เพิ่มเติม

SnakeDisk เป็น Worm ที่เน้นการแพร่กระจายผ่าน USB โดยใช้เพื่อ sideload ไบนารีที่มีลงนามอย่างถูกต้อง (legitimate signed binaries) เพื่อติดตั้ง Backdoor ที่มีชื่อว่า Yokai ซึ่งจะสร้าง reverse shell และสร้างความคงอยู่ (persistence) ผ่านการกำหนด scheduled tasks

ความพัฒนาเหล่านี้ชี้ให้เห็นการปรับแต่งระบบนิเวศมัลแวร์ของกลุ่ม Hive0154 อย่างต่อเนื่อง และการจารกรรมที่มุ่งเป้าไปยังหน่วยงานรัฐบาลและองค์กรด้านนโยบายในภูมิภาคเอเชียตะวันออก

Threat Actor Profile

Mustang Panda (หรือรู้จักในชื่อ Hive0154) เป็นกลุ่มผู้ไม่หวังดีที่มีความเชื่อมโยงกับจีน และมีประวัติการใช้งานมัลแวร์จำนวนมาก มีเทคนิคที่สม่ำเสมอ กลุ่มนี้ประกอบด้วยหลาย subcluster และดำเนินการโจมตีไซเบอร์ไปยังองค์กรทั้งภาครัฐและเอกชน รวมถึง think tanks, กลุ่มนโยบาย, หน่วยงานรัฐบาล และบุคคล

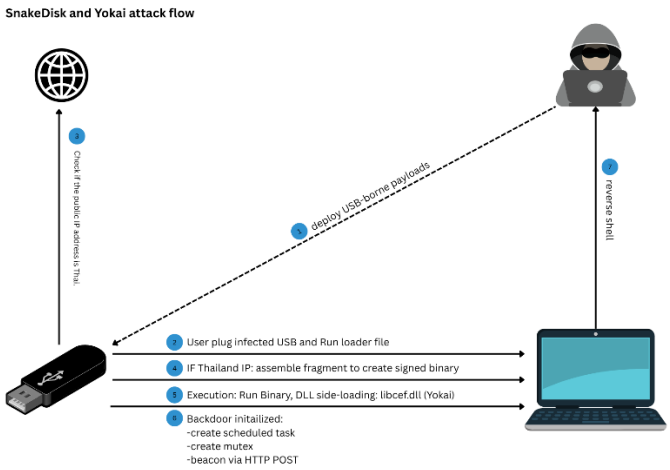
Mustang Panda มักออกแบบแคมเปญให้มีความละเอียดและเหมาะกับบริบทท้องถิ่น ใช้ธีมหรือเอกสารที่เกี่ยวข้องกับประเทศเป้าหมายหรือประเด็นทางภูมิรัฐศาสตร์เพื่อหลอกล่อผู้รับให้เปิดไฟล์หรือคลิกลิงก์ แล้วจึงฝัง payload แบบ multi-stage ที่อาศัยเทคนิคเช่น DLL sideloading, signed binary abuse และการตั้ง persistence ผ่าน scheduled tasks หรือวิธีอื่น ๆ การผสานเทคนิคเหล่านี้ทำให้กิจกรรมของกลุ่มมีความซับซ้อนและหลบเลี่ยงการตรวจจับได้ดี

จากการสังเกตของ X-Force พบว่ากลุ่มนี้ใช้ มัลแวร์ loader ที่พัฒนาขึ้นเองหลายชนิด, backdoor, และ USB worm families ซึ่งสะท้อนถึงความสามารถในการพัฒนาที่สูงของกลุ่ม Mustang Panda

การวิเคราะห์เชิงเทคนิค

Attack Flow

1. **Initial access:** Snakedisk จะทำการคัดลอกข้อมูลใน USB ที่ติดเชื้อไปไว้ยังโฟลเดอร์ย่อย และจากนั้นสร้างไฟล์ Executable ปลอมขึ้นมาโดยใช้ชื่อเหมือนกับไฟล์ที่ถูกนำไปซ่อนเอาไว้ หรือ USB.exe และทำการเช็คว่า Public IP Address ของเครื่องที่ติดเชื้อนั้นเป็น IP Address ของไทยหรือไม่
2. **Execution & DLL sideloading:** เมื่อผู้ใช้ทำการคลิกไฟล์ปลอมที่ถูกสร้างขึ้นมา ไฟล์นั้นจะทำหน้าที่เป็น loader เพื่อสร้างไฟล์ไบนารีจาก Fragments ที่ถูกเตรียมเอาไว้จากนั้นไบนารีจะทำโหลด dll ที่เป็น Yokai backdoor เข้าสู่ libcef.dll ที่อยู่ภายในโฟลเดอร์เดียวกันพร้อมทั้งนำไฟล์ที่ถูกย้ายกลับมายังตำแหน่งเดิม
3. **Post-exploitation: persistence, mutex, C2:**
    a. Yokai สร้าง persistence โดยการสร้าง Scheduled Task ที่ชื่อ "MicrosoftEdgeAcModuleUpdateTask" ให้รันตัวเองในทุกๆ 5 นาทีพร้อมกับ Argument “-project-mod”
    b. Yokai สร้าง mutex "k1tpddvivh74fo1et725okr1c1" เพื่อป้องกันไม่ให้มัลแวร์รันซ้ำซ้อนบนเครื่องเดียวกัน
    c. Yokai จะทำการสื่อสารกับ C2 ผ่าน HTTP POST ไปยังเส้นทาง /kptinfo/import /index.php ซึ่งถูก Hard-coded เอาไว้เพื่อส่งข้อมูลและรับคำสั่ง
    d. C2 สามารถที่จะเรียกใช้ reverse shell ได้ผ่าน anonymous pipes



[แผนภาพการโจมตีด้วย SnakeDisk และ Yokai backdoor]

Technique Tactics and Procedures

(MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Execution	T1059.003	Command and Scripting Interpreter — Windows Command Shell
	T1204.002	User Execution — Malicious File.
Persistence	T1574.001	Hijack Execution Flow — DLL Side-Loading.
	T1053.005	Scheduled Task.
	T1547	Boot or Logon Autostart Execution.docs.logrhythm.com
Defense Evasion	T1027	Obfuscated Files or Information.
	T1218	Signed Binary Proxy Execution
Command and Control	T1105	Ingress Tool Transfer.
	T1071.001	Application Layer Protocol — Web
Collection	T1025	Data from Removable Media

Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

SHA256:

8132beeb25ce7baed0b561922d264b2a9852957df7b6a3daacfbb3a969485c79

f8b28cae687bd55a148d363d58f13a797486f12221f0e0d080ffb53611d54231

d1466dca25e28f0b7fae71d5c2abc07b397037a9e674f38602690e96cc5b2bd4

1272a0853651069ed4dc505007e8525f99e1454f9e033bcc2e58d60fdafa4f02

b8c31b8d8af9e6eae15f30019e39c52b1a53aa1c8b0c93c8d075254ed10d8dfc

7087e84f69c47910fd39c3869a706e55324783af8d03465a9e7bfde52fe4d1d6

38fcd10100f1bfd75f8dc0883b0c2cb48321ef1c57906798a422f2a2de17d50c

69cb87b2d8ee50f46dae791b5a0c5735a7554cc3c21bb1d989baa0f38c45085c

564a03763879aaed4da8a8c1d6067f4112d8e13bb46c2f80e0fcb9ffdd40384c

e4bb60d899699fd84126f9fa0dff72314610c56fffca3d11f3b6fc93fcb75e00

c2d1ff85e9bb8feb14fd015dceee166c2e52e2226c07e23acc348815c0eb4608

bdbc936ddc9234385317c4ee83bda087e389235c4a182736fc597565042f7644

f0fec3b271b83e23ed7965198f3b00eece45bd836bf10c038e9910675bafefb1

e7b29611c789a6225aebbc9fee3710a57b51537693cb2ec16e2177c22392b546

9ca5b2cbc3677a5967c448d9d21eb56956898ccd08c06b372c6471fb68d37d7d

318a1ebc0692d1d012d20d306d6634b196cc387b1f4bc38f97dd437f117c7e20

0d632a8f6dd69566ad98db56e53c8f16286a59ea2bea81c2761d43b6ab4ecafd

39e7bbcceddd16f6c4f2fc2335a50c534e182669cb5fa90cbe29e49ec6dfd0df

05eb6a06b404b6340960d7a6cf6b1293e706ce00d7cba9a8b72b3780298dc25d

dd694aaf44731da313e4594d6ca34a6b8e0fcce505e39f8273b9242fdf6220e0

bb5bb82e5caf7d4dbbe878b75b23f793a5f3c5ca6dba70d8be447e8c004d26ce

35bec1d8699d29c27b66e5646e58d25ce85ea1e41481d048bcea89ea94f8fb4b

URL:

hxxp://118.174.183[.]89/kptinfo/import/index.php

Domain:

www.slickvpn[.]com

IP:

123.253.34[.]44

146.70.29[.]229

188.208.141[.]196

แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- ระมัดระวังการใช้ USB และการเรียกใช้งานไฟล์ที่ไม่รู้จักแหล่งที่มา
- ตรวจจับและบล็อก DLL sideloading: เฝ้าตรวจสอบการโหลด DLL ที่ผิดปกติจากไฟล์ปฏิบัติการที่ลงนาม และแจ้งเตือนเมื่อพบไฟล์ปฏิบัติการที่ลงนาม (Signed executable) เรียก cmd.exe พร้อมอาร์กิวเมนต์ที่ไม่คาดคิด (เช่น -Embedding, —project-mod)
- เฝ้าตรวจสอบการสร้าง scheduled tasks (Event ID 4698) และติดธงพิเศษสำหรับ task เช่น MicrosoftEdgeAcModuleUpdateTask หรือ task ที่เรียกใช้ binary ที่ไม่รู้จักด้วยอาร์กิวเมนต์ -project-mod

การป้องกัน (Prevention)

- บังคับใช้นโยบายควบคุมสื่อถอดได้: จำกัดการเขียน/การรันไฟล์จาก USB ในกรณีที่เป็นไปได้ตามการปฏิบัติงาน และใช้กฎ DLP/EDR บน endpoint เพื่อตรวจจับ directory ที่ซ่อน, ไฟล์ปฏิบัติการที่ตั้งชื่อตาม volume-name

การรับมือ (Response)

- เก็บหลักฐานทางดิจิทัลโดยถอด USB และกักเก็บเป็นหลักฐาน
- ตัดการเชื่อมต่อโดยบล็อกโดเมนหรือ IP ของ C2
- ตรวจสอบการเชื่อมต่อ: ตรวจสอบ outbound network connections and proxy logs ที่เป็น HTTP POST ไปยัง /kptinfo/import/index.php
- ลบ scheduled task และหยุด process ที่ถูกสร้างขึ้นโดยมัลแวร์
- แจ้งเหตุการณ์ไปยังหน่วยงานที่เกี่ยวข้องภายในองค์กรและหน่วยงานด้านความมั่นคงปลอดภัยไซเบอร์

อ้างอิง (References)

1. CYBLE Treat Advisory
2. IBM article " Hive0154, aka Mustang Panda, drops updated Toneshell backdoor and novel SnakeDisk USB worm" https://www.ibm.com/think/x-force/hive0154-drops-updated-toneshell-backdoor

แบบประเมินรายงานข่าวกรองไซเบอร์

https://dg.th/nsexlfob51

จัดทำโดย

ฤทธิ์นภา ประเสริฐศรี

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน
ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ
โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th